

CYBER SECURITY

UNIT -1

-Sonali Singh

INTRODUCTION TO CYBER CRIME :

- Cybercrime- Definition and Origins of the word Cybercrime and Information Security,
- Who are Cybercriminals?
- Classifications of Cybercrimes,
- A Global Perspective on Cybercrimes, Cybercrime Era: Survival Mantra for the Netizens.
- Cyber offenses: How Criminals Plan the Attacks, Social Engineering, Cyber stalking, Cybercafe and Cybercrimes,
- Botnets: The Fuel for Cybercrime,
- Attack Vector.

Let's break the term “Cyber Security”

- **Cyber** : Cyber comes from the word **cybernetics**, which relates to computers, digital systems, and communication networks.

So we can say , **anything that exists or operates in the digital/online world** is called cyber .

- **Security** : Security means **protection or safety**. It involves:
 - Preventing damage or harm
 - Keeping things safe from danger
 - Protecting information from being stolen, changed, or destroyed
 - In general, security is about **defending something valuable**.

- **Cyber Security** : Cyber Security is about protecting computer systems, networks, applications, and data from cyber attacks, unauthorized access, damage, or disruption by implementing security policies, technologies, and controls.

□ Why cyber security is important ?

- Protects confidential data (personal, financial, academic)
- Prevents **data breaches** and cyber crimes.
- Important for IT industries, government, banking, healthcare, etc.

CyberCrime

Cybercrime is any illegal activity carried out using a computer, digital device, or network, where the computer is either a tool, a target, or both.

Cybercrime Can Be:

- **Computer as a Target**

- Hacking
- Website defacement
- Data breaches

- **Computer as a Tool**

- Online fraud
- Cyberstalking
- Phishing emails

- **Computer as Both**

- Ransomware attacks
- Malware injection

simple scenarios:

- ATM fraud using cloned cards
- Fake job offers via email
- WhatsApp account hacking
- Online exam paper leaks

Origins of the Word “Cybercrime”

- The term “**Cyber**” originates from “**Cybernetics**”, a field introduced by **Norbert Wiener** in the 1940s. Cybernetics refers to the study of **control and communication systems** in machines and living beings.
- Back in the 1990s, when computers were becoming popular globally, people needed a word for these new digital crimes. So, they created "cybercrime" to describe illegal activities happening in the digital space.

Evolution of Cybercrime:

- 1. Pre-Internet Era (1960s–1970s)(Birth of Computer Crime):** Early computer misuse (unauthorized access).
- 2. Early Networking Era (1980s)(Rise of Hacking):** First known hacking incidents and computer viruses
- 3. Internet Expansion Era 1990s (Globalization of Cybercrime)** Growth of the internet → online piracy, email scams, website defacement, credit card fraud
- 4. Early 2000s : organized and financial Cybercrime :** financial fraud ,Phishing attacks ,Spyware and trojans ,identity theft, introduction of IT Act , 2000
- 5. Social Media and Mobile Era (2010–2015): Mass Victimization**

- Social engineering, Cyberstalking, Fake profiles, Mobile banking fraud, Mobile-based cybercrime

6. Advanced Persistent Threat Era (2016–2020): Sophistication:-

Ransomware attacks, Advanced Persistent Threats (APTs), Corporate data breaches

7. Pandemic and Remote Work Era (2020–2022): Opportunistic Cybercrime: -

COVID-related phishing, Fake donation scams, Zoom meeting hijacking

8. Current Era (2023–Present): AI-Driven and State-Sponsored Cybercrime:-

Deepfake frauds, Crypto scams, AI-powered phishing, Cyber warfare

Cybercrime vs Traditional Crime

- **Traditional Crime**

- Traditional crime refers to illegal activities committed in the **physical world**, involving physical interaction between the criminal, victim, or property.
- **Examples:** Theft, Robbery, Murder, Physical fraud, Vandalism

- **Cybercrime: -**

- Cybercrime refers to illegal activities committed using **computers, digital devices, or computer networks**, where cyberspace is used to carry out

the crime.

- **Examples:**

- Hacking
- Online fraud
- Identity theft
- Ransomware attacks
- Cyberstalking

Differences Between Cybercrime and Traditional Crime

Parameter	Traditional Crime	Cybercrime
Nature of Crime	Physical in nature	Digital/virtual in nature
Location	Occurs at a specific physical place	Occurs in cyberspace
Physical Presence	Criminal and victim may meet	No physical interaction
Geographical Boundaries	Usually local or national	Global and borderless
Speed of Crime	Generally slower	Extremely fast
Scale of Impact	Limited to few victims	Can affect millions
Evidence	Physical evidence (weapons, fingerprints)	Digital evidence (logs, IP addresses)
Anonymity	Criminal identity often visible	Criminals hide identity
Tools Used	Physical tools (weapons, vehicles)	Computers, malware, networks
Detection	Relatively easier	Complex and technical
Law Enforcement	Local police involvement	Requires cyber cells and experts
Legal Framework	IPC and criminal laws	IT Act, cyber laws, international laws

- **Reasons for the Growth of Cybercrime**

- Rapid increase in internet users
- Digital payments and online services
- Lack of cybersecurity awareness
- Weak system security
- High financial gain with low risk
- Difficulty in tracing criminals

- **Impact of Cybercrime**

- **On Individuals**

- Financial loss
- Privacy violation
- Psychological stress

- **On Organizations**

- Data loss
- Reputation damage
- Legal penalties

- **On Nations**

- National security threats
- Economic instability
- Cyber warfare risks

Stages of Cyber Attack Lifecycle

1. Reconnaissance

Scanning the environment or harvesting information from social media.



3. Delivery

Transmission of weapon/malware to target (e.g. via email, USB, website).



5. Installation

The weapon installs malware on the system.



7. Action on objectives

With hands on access the attacker and achieve their objective.



2. Weaponization

Pairing malicious code with an exploit to create a weapon (piece of malware).



4. Exploitation

Once delivered, the weapons/malware code is triggered upon an action. This in turn exploits the vulnerability.



6. Command and Control

A command channel for remote manipulation of the victim.



Cyber Attack Lifecycle:

- A cyber attack is not a single action but a *systematic process* carried out in multiple stages by an attacker to compromise a target system. These stages are collectively known as the **Cyber Attack Lifecycle**.

1. Reconnaissance (Information Gathering)

- This is the **first stage** of a cyber attack, where the attacker collects information about the target system.

Activities involved:

- Identifying IP addresses and domain names
- Gathering employee or user information
- Scanning websites and social media
- Network scanning and foot printing

- **Objective:**

To understand the target's vulnerabilities and plan the attack.

- **Example:**

Collecting email IDs of employees for a phishing attack.

2. Scanning and Enumeration

- In this stage, attackers actively probe the target system to identify **open ports, services, and vulnerabilities**.

Activities involved:

- Port scanning
- Vulnerability scanning
- Network mapping
- Identifying operating systems and software versions

- **Objective:**

To find weak points that can be exploited.

3. Gaining Access (Exploitation): This is the stage where the attacker **exploits vulnerabilities** to gain unauthorized access.

Techniques used:

- SQL injection
- Phishing attacks
- Password cracking
- Exploiting unpatched software
- Exploit vulnerabilities

- **Objective:**

To enter the system and establish control.

4. Privilege Escalation: After gaining initial access, attackers attempt to **increase their access rights**.

Activities involved:

- Exploiting system misconfigurations
- Using stolen admin credentials
- Exploiting kernel or software flaws

Objective:

To gain administrative or root-level access.

5. Maintaining Access (Persistence)

- In this stage, attackers ensure they can **retain access** even if the system restarts or credentials change.

Techniques used:

- Installing backdoors
- Creating hidden user accounts
- Using rootkits or malware

Objective:

Long-term control over the compromised system.

6. Command and Control (C2)

- The compromised system communicates with the attacker's remote server through Botnet connections, encrypted communication and malware callbacks .
- **Activities involved:**
 - Sending stolen data
 - Receiving attack instructions
 - Coordinating further attacks
- **Objective:**
 - To remotely manage compromised systems.

7. Data Exfiltration : Here, attackers steal sensitive data from the system.

- **Data targeted:**

- Personal information
- Financial data
- Intellectual property
- Login credentials
- Ransomware deployed
- System damage

- **Objective:**

Data theft for financial gain or espionage.(finding out information about another country or organization)

8. Covering Tracks : This is the final stage, where attackers erase evidence of the attack.

- **Activities involved:**

- Deleting logs
- Disabling security alerts
- Modifying timestamps

- **Objective:**

To avoid detection and prolong access.

Who are Cybercriminals?

- A cybercriminal is a person who uses his skills in technology to do malicious acts and illegal activities known as cybercrimes. They can be individuals or teams.
- Cybercriminals are widely available in what is called the “Dark Web” where they mostly provide their illegal services or products.
- Not every hacker is a cybercriminal because hacking itself is not considered a crime as it can be used to reveal vulnerabilities to report and patch them which is called a “white hat hacker”.
- Cybercriminals can be individuals who are trading in illegal online content or scammers or even drug dealers. **So here are some examples of cybercriminals:**
 - Black hat hackers, Grey Hat Hacker
 - Cyberstalkers
 - Cyber terrorists
 - Scammers

CLASSIFICATIONS OF CYBER CRIMES

- Cyber crimes can be classified in to 4 major categories as the following:

- (1) Cyber crime Against Individual

- (2) Cyber crime Against Property

- (3) Cyber crime Against Organization

- (4) Cyber crime Against Society

1. Cyber crime against Individual :

These crimes violate an individual's **privacy, dignity, mental peace, financial security, or reputation** using computers, mobile devices, or the internet. With increased use of social media, online banking, and digital communication, individuals have become highly vulnerable to such crimes.

1. Cyber Stalking

- Cyber stalking involves **repeated harassment, monitoring, or threatening behavior** carried out through digital platforms such as emails, social media, or messaging apps.

Key Features:

- Continuous unwanted messages or emails
- Tracking online activity
- Sending threats or intimidating content

Impact:

Causes mental stress, fear, emotional trauma, and sometimes physical danger.

2. Identity Theft

- Identity theft occurs when a criminal **steals personal information** such as name, Aadhaar number, PAN card details, passwords, or bank credentials to impersonate the victim.

Methods Used:

- Phishing emails and fake websites
- Data breaches
- Malware and spyware

Impact:

Financial loss, damage to credit score, and legal complications for the victim.

3. Phishing and Online Fraud

- Phishing is a deceptive practice where attackers **pretend to be trusted entities** (banks, government agencies, companies) to trick individuals into revealing sensitive information.

Common Forms:

- Fake bank emails or SMS (smishing)
- Fraudulent phone calls (vishing)
- Fake online shopping websites

Impact:

Loss of money, misuse of personal data, and breach of privacy.

4. Online Defamation

- Online defamation involves **publishing false, offensive, or misleading content** about an individual on digital platforms to harm their reputation.

Examples:

- Posting fake allegations on social media
- Sharing manipulated images or videos
- Spreading false rumors through blogs or messages

Impact:

Social humiliation, loss of employment opportunities, and emotional distress.

5. Cyber Bullying and Online Harassment

- Cyber bullying refers to **using digital platforms to insult, threaten, or humiliate** an individual repeatedly.

Forms:

- Abusive messages and comments
- Trolling
- Public shaming

Impact:

Low self-esteem, anxiety, depression, and in extreme cases, suicidal tendencies—especially among teenagers.

Cybercrimes Against Property

- Cybercrimes against property refer to **illegal activities that cause damage, destruction, theft, or unauthorized control of digital property**. In the cyber world, property includes **data, software, computer systems, networks, and intellectual property**. These crimes result in **financial loss, operational disruption, and loss of competitive advantage**.

1. Hacking (Unauthorized Access)

- Hacking is the act of **gaining unauthorized access** to a computer system, network, or digital device with malicious intent.

Objectives:

- Steal sensitive data
- Modify or destroy information
- Disrupt normal system operations

Impact:

Loss of data integrity, confidentiality breaches, and financial damage.

(2) Credit Card Fraud : As the name suggests, this is a fraud that happens by the use of a credit card. This generally happens if someone gets to know the card number or the card gets stolen.

(3) Intellectual Property crimes : .

- This crime involves **unauthorized use, reproduction, or distribution of protected digital content.**

Examples:

- Software piracy
- Copyright infringement
- Theft of designs, research data, or source code

Impact:

Revenue loss, reduced innovation, and legal disputes.

3. Cyber crime Against Organization

Cybercrime against organizations refers to illegal activities carried out using digital technologies that target businesses, corporations, educational institutions, hospitals, or non-profit organizations.

1. Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks

- In a DoS or DDoS attack, attackers **overwhelm an organization's servers or networks with excessive traffic**, making services unavailable to legitimate users.

Targets:

- Websites
- Online banking systems
- E-commerce platforms

Impact:

Business disruption, revenue loss, customer dissatisfaction, and reputational damage.

2. Corporate Espionage (Cyber Espionage)

- Corporate espionage involves the **theft of confidential business information** such as trade secrets, research data, business strategies, or customer databases.
- Methods Used:
 - Hacking and malware
 - Phishing attacks
 - Insider threats
- Impact:
Loss of competitive advantage and long-term financial damage.

3. Insider Attacks

- Insider attacks occur when **employees or authorized users misuse their access privileges** for malicious purposes.

Examples:

- Stealing confidential data
- Sabotaging systems
- Sharing sensitive information with competitors

Impact:

Difficult to detect, leading to severe security breaches and trust issues.

4. Ransomware Attacks

- Ransomware is a type of malware that **encrypts organizational data and demands payment** in exchange for restoring access.

Targets:

- Hospitals
- Educational institutions
- Corporate databases

Impact:

Operational paralysis, financial loss, and potential data leaks.

v) Salami Attack :

- This attack is for committing financial fraud.
- The salami attack involves a malicious developer or a hacker who has access to the code base of a target application. The code is modified such that on every transaction a negligible amount

example Rs. 2 is shaved off from the consumer's account. The individual consumer might not notice the amount debited as it is negligible. But if we consider a large number of consumers or buyers, the amount is huge and is a significant benefit to the developer or the hacker.

4) Cyber crime Against Society:

- **Crimes Against Society** are offenses that don't just harm an individual victim—they undermine **public order, national security, morals, or the collective well-being of society**. Because their impact is broad, states treat them as serious crimes and often punish them harshly.
- Examples: Cyberterrorism, forgery (counterfeit documents), child pornography, and online gambling.

1. Cyberterrorism:

- Cyberterrorism is the use of **digital attacks** to create fear, chaos, or serious disruption for political, ideological, or religious goals.

Key Characteristics

- Targets **critical infrastructure** (power grids, hospitals, banks, government systems)
- Conducted through **computers, networks, or the internet**
- Intends to cause **panic, economic loss, or national instability**

- **Examples**

- Hacking a national power grid to shut down electricity
- Disrupting hospital systems during emergencies
- Attacking government databases to destabilize a country

2. **Forgery (Counterfeit Documents)**

- Forgery involves **creating, altering, or using fake documents** with intent to deceive.

- **Common Types**

- Fake passports or visas
- Counterfeit currency
- Forged academic certificates

- Fake government IDs or licenses

- **Why It's a Crime Against Society**

- Destroys **trust in official documents**
- Enables other crimes (fraud, illegal immigration, identity theft)
- Undermines government authority and economic stability

- **Social Impact**

- Weakens financial systems
- Compromises border security
- Harms institutions like schools, banks, and courts

3. Child Pornography (Child Sexual Abuse Material)

- This crime involves the **creation, possession, distribution, or viewing** of sexually explicit material involving minors.

- **Why It's Classified as a Crime Against Society**

- It represents **severe exploitation and abuse of children**
- Each image or video is evidence of **ongoing harm**
- Its existence fuels organized criminal networks

- **Societal Harm**

- Violates fundamental human rights

- Causes lifelong psychological trauma to victims
- Erodes moral and ethical foundations of society
- **Legal Position**
- **Zero tolerance worldwide**
- Severe penalties, including long-term imprisonment
- International cooperation for detection and prosecution
- Even possession alone is considered a serious crime in most countries.

5. Online Gambling (Illegal)

Online gambling becomes a crime when it:

- Operates without government authorization
- Targets minors
- Involves money laundering or fraud

Why It's a Crime Against Society

- Illegal online gambling:
- Encourages addiction and financial ruin
- Is often linked to organized crime
- Evades taxes and regulation

• Social Consequences

- Family breakdowns
- Increased debt and crime
- Exploitation of vulnerable populations

• Legal Treatment

- Many countries ban or strictly regulate it
- Websites may be blocked
- Operators and participants can face fines or imprisonment

6. WebJacking:

Web Jacking Web jacking occurs when someone forcefully takes control of a website (by cracking the password and later changing it) Thus, the first stage of this crime involves “password sniffing” The actual owner of the website does not have any more control over what appears on that website.

Relationship Between Cybercrime and Information Security

- Information Security

Information Security is the practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to ensure confidentiality, integrity, and availability of information.

Core Objectives of Information Security (CIA Triad)

- **Confidentiality** – Protecting data from unauthorized access
- **Integrity** – Ensuring data is accurate and unaltered
- **Availability** – Ensuring data and systems are accessible when needed

Types of Information Security

1. Data Security
2. Network Security
3. Application Security
4. Physical Security
5. Operational Security
6. Human Security
7. Database security
8. Cloud security

1. Data Security

Data security refers to protecting digital and physical data from unauthorized access, corruption, theft, or loss.

- **Objectives**

- Ensure **confidentiality** (only authorized access)
- Maintain **integrity** (data remains accurate and unaltered)
- Guarantee **availability** (data accessible when needed)

- **Key Measures**

- Encryption (at rest and in transit)
- Data masking and tokenization
- Access control policies
- Backup and disaster recovery
- Data Loss Prevention (DLP) systems
- **Example**
- Encrypting customer information in a banking database to prevent data breaches.

2. Network Security

- Network security protects computer networks and data transmission from intrusions, misuse, and cyberattacks.
- **Objectives**
- Prevent unauthorized network access
- Detect and respond to attacks
- Protect internal and external communications
- **Key Measures**

- Firewalls
- Intrusion Detection/Prevention Systems (IDS/IPS)
- VPNs (Virtual Private Networks)
- Network segmentation
- Secure Wi-Fi configurations
- **Example**
- Using a firewall to block suspicious IP addresses from accessing a company's internal network.

• 3. Application Security

- Application Security refers to the protection of software applications from vulnerabilities and threats throughout the **software development life cycle (SDLC)**. **Example:** Fixing SQL injection vulnerabilities in a web application.
- Many cyberattacks exploit flaws in application design or coding, making this area extremely important.
- Application security involves

secure coding practices, code reviews, vulnerability assessments, penetration testing, authentication and authorization controls, and regular patch updates.

- It protects applications from threats such as **SQL injection, cross-site scripting (XSS), buffer overflow, and logic flaws**. Strong application security ensures software reliability, user trust, and system integrity.

• 4. Physical Security

- Physical Security addresses the protection of **hardware, infrastructure, and physical facilities** that store and process information.
- Even the most advanced digital security measures can fail if physical access to systems is not controlled.
- Physical security measures include **access control systems, surveillance cameras, biometric authentication, security guards, and environmental controls such as fire suppression and temperature regulation, Locked server rooms.**
- It prevents threats such as **theft, sabotage, vandalism, and natural disasters, ensuring the safety and availability of critical information assets.**

5. Operational Security

- Operational Security (OPSEC) focuses on the **processes, policies, and procedures** used to manage and protect information systems during daily operations.
- It ensures that security controls are effectively implemented and maintained.
- Operational security includes risk management, incident response planning, change management, disaster recovery, business continuity planning, and compliance with cybersecurity standards.
- It helps organizations detect, respond to, and recover from security incidents efficiently, minimizing operational and financial impact.

6. Human Security

- Human Security recognizes that **humans are often the weakest link** in information security.
- Many cyber incidents occur due to human error, negligence, or malicious insider activity rather than technical failures.
- This area emphasizes security awareness training, ethical behavior, role-based access control, and protection against social engineering attacks such as phishing and impersonation.
- By educating users and promoting a security-conscious culture, organizations can significantly reduce cyber risks.

7. Cloud Information Security

- Protects data, applications, and services hosted in the cloud.

Examples: cloud access security brokers (CASB), secure configurations, encryption in cloud storage.

8. Database Security

Protects structured data stored in databases

Survival Mantra for the Netizens

- The term “**Netizen**” was coined by **Michael Hauben**.
- Simply, netizens are the Internet users.
- Therefore, netizen is someone who spends considerable time online and also has a considerable presence online.
- **The 5P Netizen Mantra**—
 - **Precaution,**
 - **Prevention,**
 - **Protection,**
 - **Preservation,**
 - **Perseverance**

- **Precaution:** Precaution refers to risk awareness and cautious interaction with digital systems.

Knowledge is the first line of defense. Netizens must stay informed about:

- Avoid using untrusted software libraries and APIs
- Verify the authenticity of emails, repositories, and software updates
- Follow secure coding practices to reduce human errors.
- Be cautious while accessing unknown networks or devices
- Latest cyber threats and scams
- Safe browsing habits
- Privacy settings on social media platforms

✓ *Educational institutions and governments should promote cyber literacy programs*

Prevention: Prevention focuses on **eliminating security loopholes during system design and implementation**. Engineers play a crucial role in preventing cyberattacks through secure architecture

- Use **strong and unique passwords** for different accounts.
- Enable **two-factor authentication (2FA)** wherever possible.
- Avoid sharing passwords or OTPs with anyone.
- Secure configuration of servers, databases, and network devices

Ethical Use of Technology

- Responsible and ethical use of digital resources reduces cyber risks. Netizens should:
- Respect others' privacy
- Avoid spreading misinformation
- Follow cyber ethics and netiquette

Protection: Protection involves technical safeguards that defend systems and data from attacks.

- Use of firewalls,
- intrusion detection and prevention systems (IDS/IPS)
- Data encryption at rest and in transit
- Secure communication protocols such as HTTPS, SSL/TLS
- Code obfuscation and secure firmware updates
- Regularly update software and antivirus programs.
- Limit sharing of personal information on social media.
- Review app permissions and privacy policies carefully.

Preservation:

Safe Online Behavior

- Do not click on suspicious links or attachments.
- Verify the authenticity of emails, websites, and messages.
- Avoid using public Wi-Fi for financial transactions.
- Regular system and database backups
- Log management and audit trails for incident analysis
- Preserving digital evidence for forensic investigation
- Ensuring business continuity and disaster recovery planning

Perseverance:

- Netizens must be aware of cyber laws such as:
- Information Technology Act, 2000 (India)
- Cybercrime reporting mechanisms- Legal awareness empowers users to take timely action against cyber offenders.
- Stay updated with evolving cyber threats and technologies
- Continuously test and update security mechanisms
- Follow cybersecurity standards such as ISO/IEC 27001 and NIST
- Promote ethical engineering and responsible technology use

Cybercafe

A **cybercafe** is a public place where people can use computers and internet services by paying a small fee. It plays an important role in helping people access digital services, especially in areas where personal internet facilities are limited.

It became very popular in the late 1990s and early 2000s,

People pay based on time (per hour or per minute) or per service (like printing per page).

Main Services Offered

1. Internet Browsing
2. Printing and Scanning
3. Online Form Filling
4. Gaming

5. Other Services:- Typing work, Resume creation, Passport-size photo editing, CD/DVD writing (earlier common)

Why Cybercafes Are Important

Cybercafes are important because:

1. Access for Everyone

Not everyone has:

- A computer
- A printer
- High-speed internet

Cybercafes help students, job seekers, and small business owners.

2. Rural and Small Town Support

In places like small towns or villages:

- Many government services are online.
- Cybercafes help people complete digital tasks.

3. Affordable Option

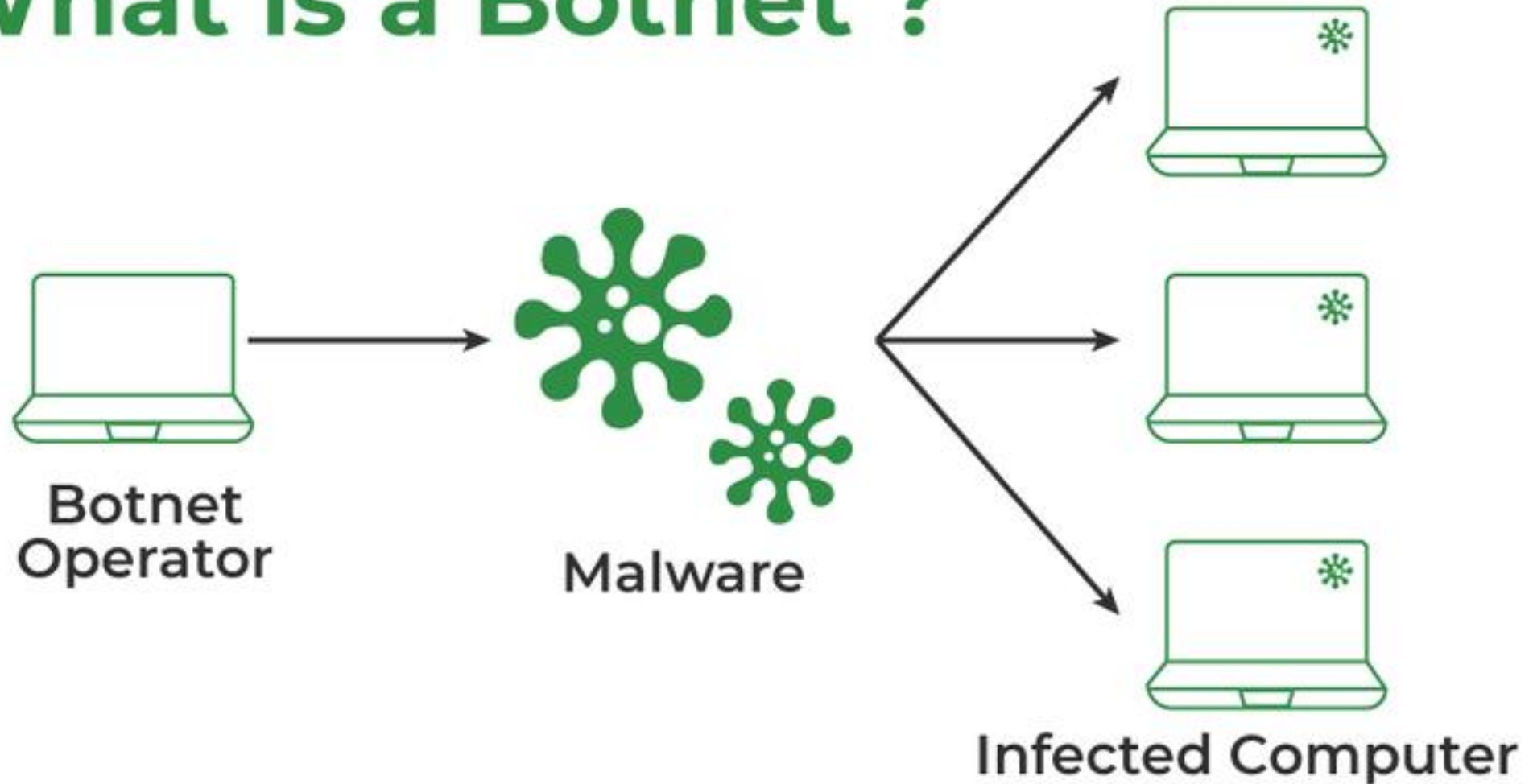
Instead of buying a computer, people can pay a small amount (for example ₹20–₹50 per hour).

Botnets: The Fuel for Cybercrime

- A **botnet** (short for *robot network*) is a collection of internet-connected devices that have been infected with malware and are remotely controlled by an attacker, often called a *botmaster or threat actor*.
- These compromised devices—known *as bots or zombies*—can include personal computers, servers, smartphones, and increasingly, Internet of Things (IoT) devices such as routers and CCTV cameras.
- “A **botnet** is a group of computers or devices that have been secretly infected with malware and are controlled by a hacker without the owners knowing.”

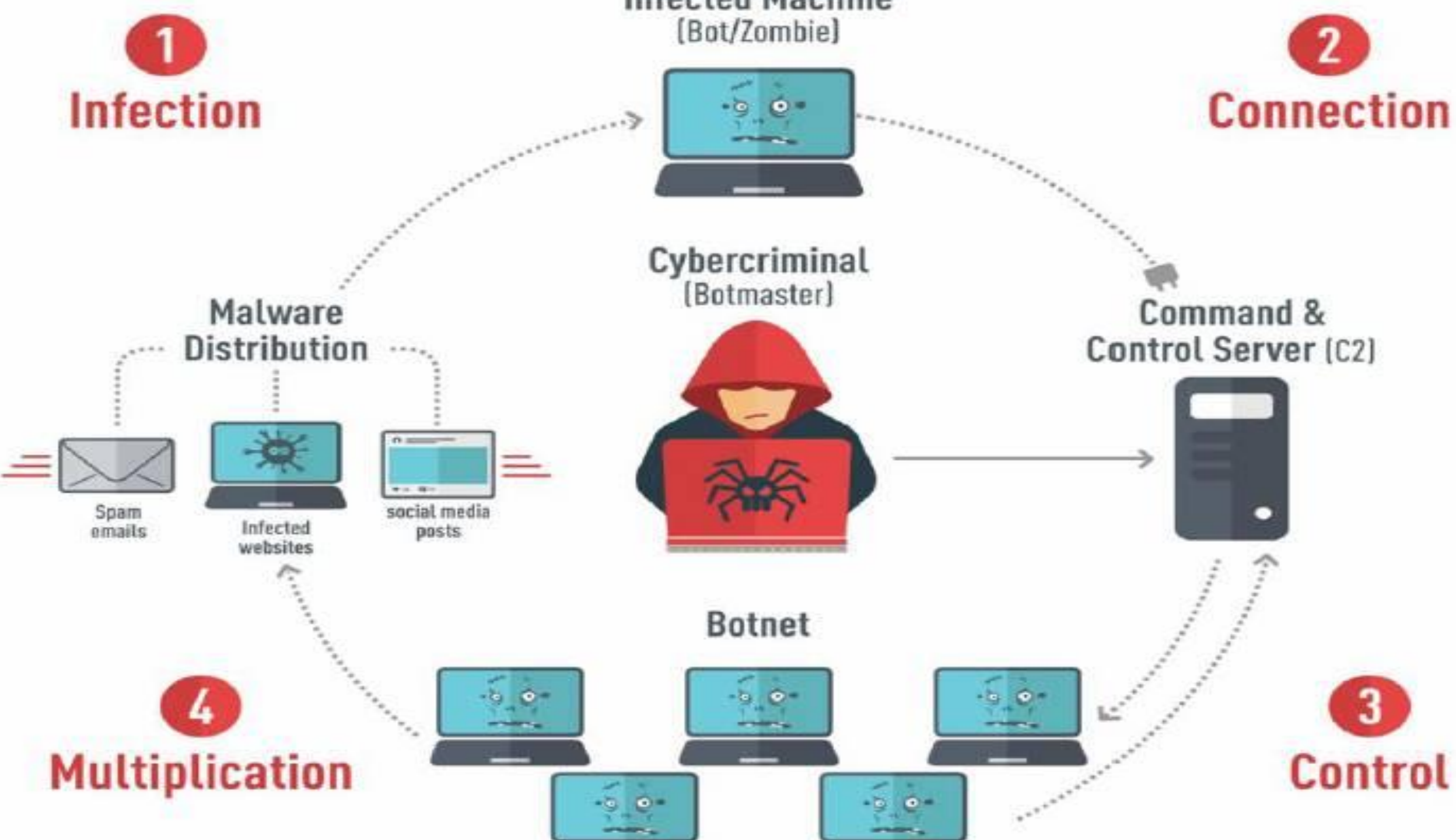
Botnets: The Fuel for Cybercrime

What is a Botnet ?



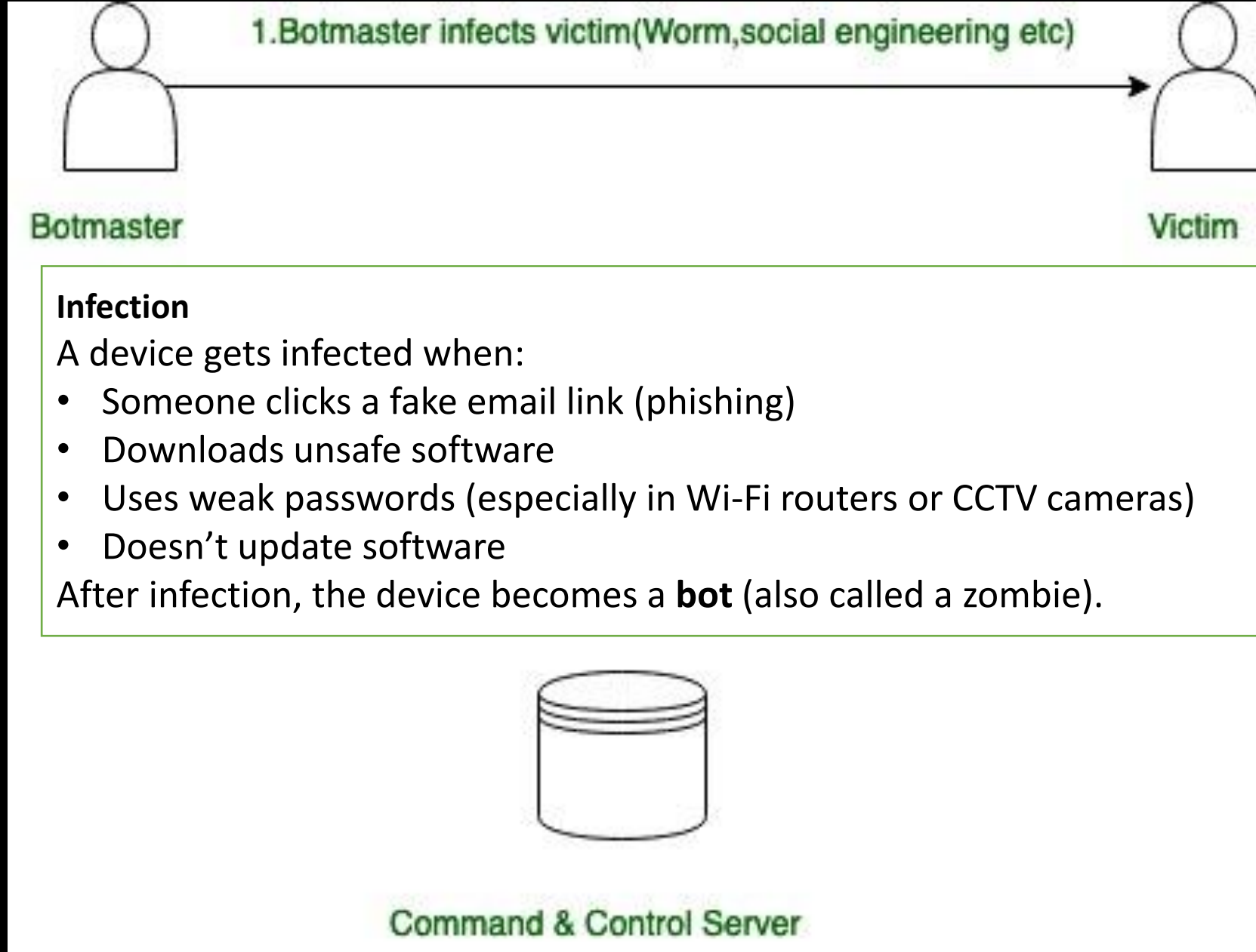
Types and Techniques of Botnet Attacks

1. DDoS Attacks
2. Spam and Phishing Campaigns
3. Financial Fraud and Credential Theft
4. Ransomware Distribution
5. Cryptocurrency Mining: Some botnets hijack computing power to mine cryptocurrency without user consent (cryptojacking).



Botnet Lifecycle : Botnet Lifecycle can be understood with the help of the following diagrams. Here we have illustrated the lifecycle of Botnet in 4 stages as shown in the figure.

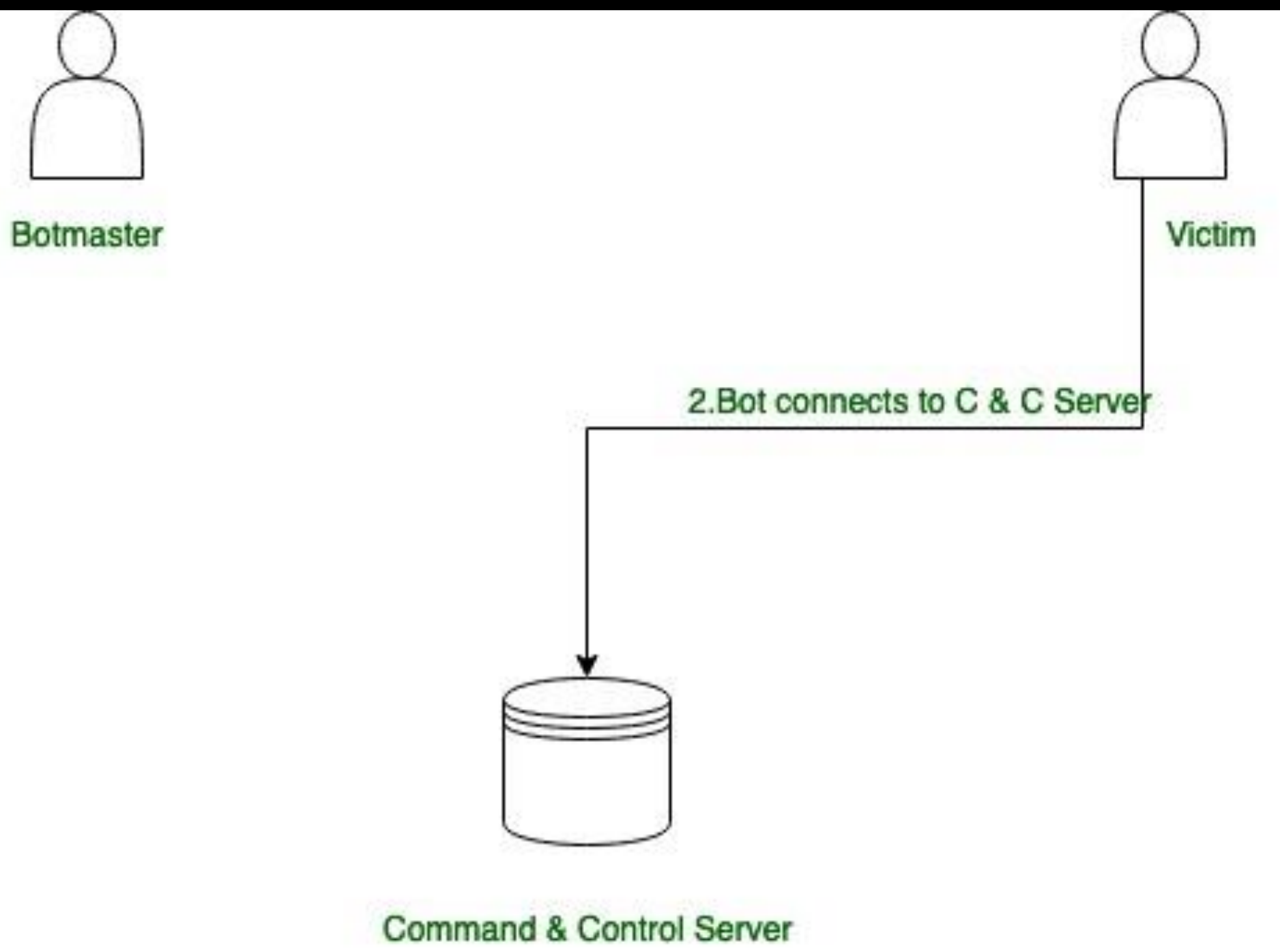
- **Stage-1**



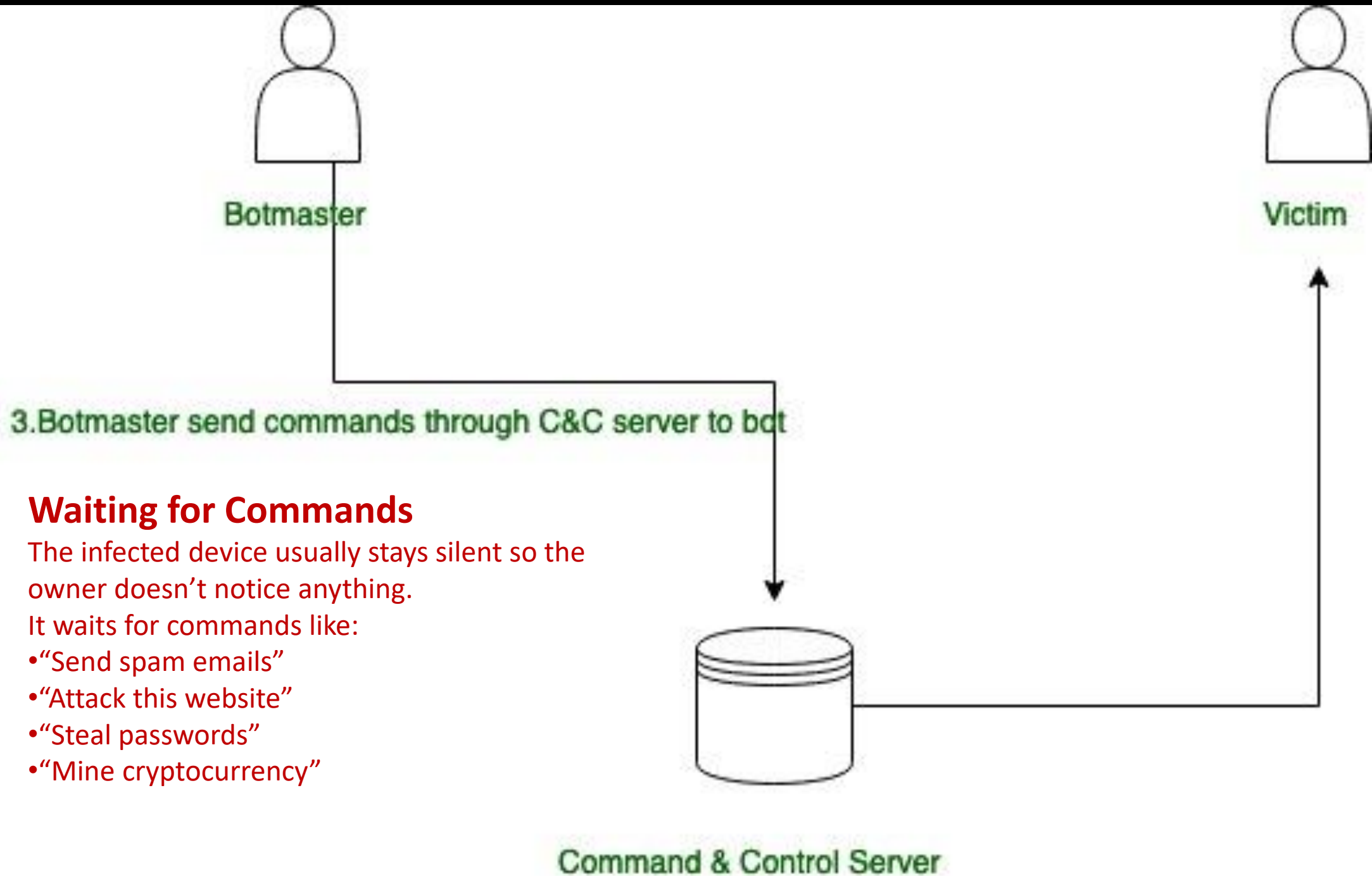
Stage 2.

Connecting to the Hacker

Once infected, the device secretly connects to a **command and control (C2) server** controlled by the hacker. Think of it like this: Your device quietly reports to a “boss computer” and waits for instructions. The hacker can control thousands or even millions of such devices at the same time.



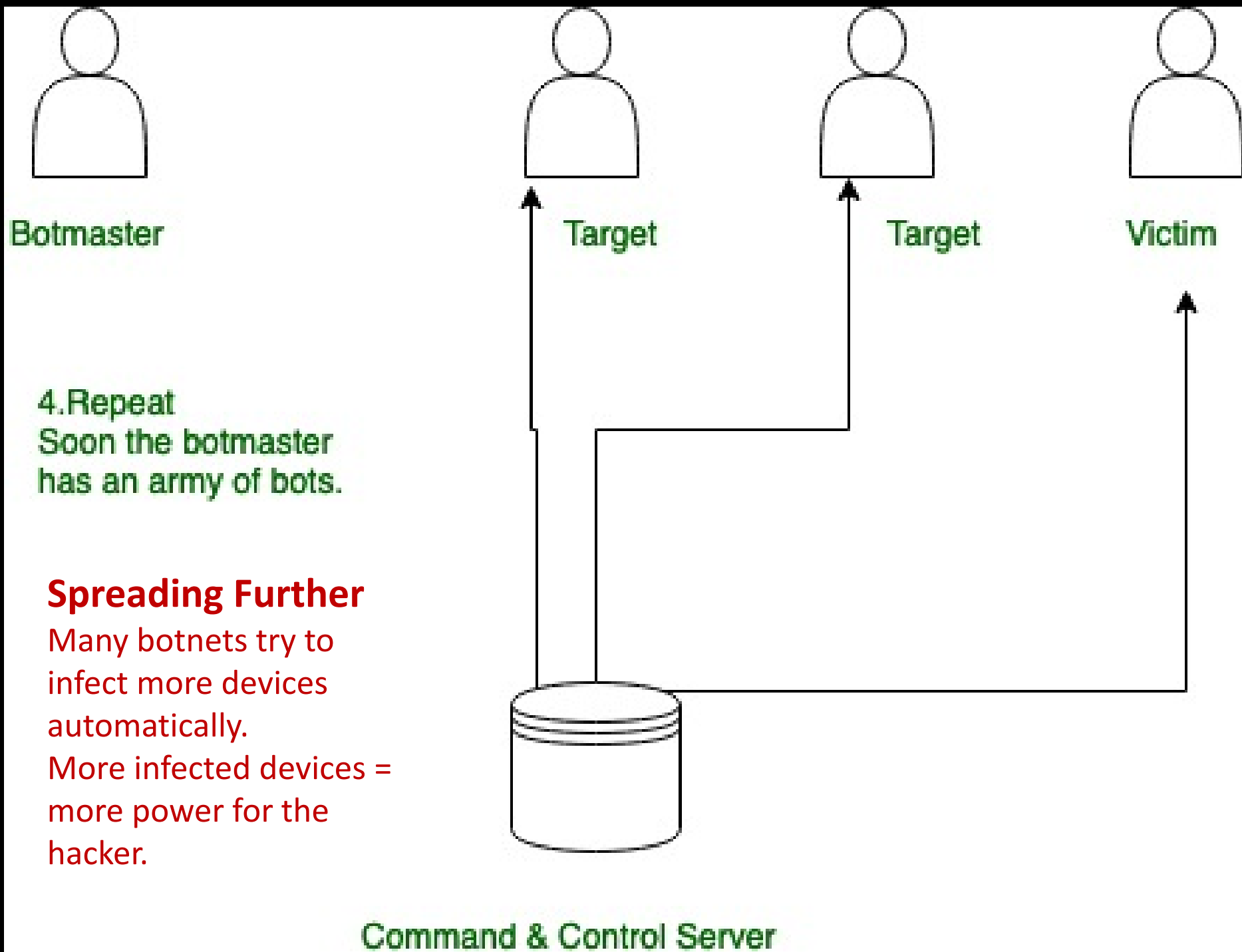
Stage 3



Stage 4.

Performing the Attack

When the hacker sends instructions, all infected devices act together.



Simple Real-Life Analogy

Think of it like this:

- The hacker is a *gang leader*.
- Infected devices are *gang members*.
- The C2 server is the *communication center*.
- When the leader gives an order, all members act together.

But the “gang members” (your devices) don’t even know they are part of a gang!

How to Protect Against Botnets?

- The most important way to protect from Botnets is to give training to users about identifying suspicious links.
- Keep the system software always updated to become safe from the Botnets.
- Using two-factor authentication is a way to be safe from the Botnet.
- There are several antiviruses present in the market which keeps you protected from Botnets.
- Try to change passwords on a regular basis for better protection from Botnets.

• **What is Attack Vectors?**

- **Attack vectors are the specific paths or methods that cyber attackers use to gain unauthorized access to a system, network, or application.**
- These vectors serve as entry points for attacks, allowing malicious actors to exploit vulnerabilities.
- Every ethical hacker has their unique attack vector to check the security of the target application, this application may be a web application or an android application.
- **They take advantage of weaknesses or flaws in the system to steal information, cause damage, or gain control.**

Attack Vectors



Social engineering

Malware

Web-based

Network-based

Physical attacks

Password attacks

Weakness

Weakness

Weakness

Attack surface

Network



Endpoints

Servers

• **What is an Attack Surface?**

- An attack surface refers to all the locations, interfaces, or channels by which an attacker may obtain unauthorized access to a system, network, or application.
- It comprises the entire vulnerabilities, access points, and potential channels of attack that exist inside an organization's cyberspace.

Social Engineering:

- **Social engineering** is the deliberate psychological manipulation of individuals to make them reveal confidential information, grant unauthorized access, or perform actions that compromise security.
- Unlike technical attacks (which exploit software vulnerabilities), social engineering exploits **human behavior, trust, emotions, and cognitive weaknesses**.
- Organizations such as the Federal Bureau of Investigation consistently report that social engineering—especially phishing—is one of the most common starting points of cybercrime.

Types of Social Engineering Attacks

1. Phishing

2. Vishing(voice phishing)

- Attackers call victims pretending to be:
- Bank officials
- IT support staff
- Government officers
- With AI voice cloning technology, impersonation has become more realistic.

3. Smishing (SMS Phishing) Fraudulent SMS messages such as:

- “Your parcel is delayed. Click here.”
- “Update your KYC immediately.”

4. Pretexting

- Creating a fake story (pretext) to gain

information.

5. Baiting

- Leaving infected USB drives labeled “Confidential” to trigger curiosity.

6. Tailgating (Physical Social Engineering)

- Following an authorized person into a secure building without authentication.

7. Business Email Compromise (BEC)

Attackers impersonate executives and instruct employees to transfer money.

This type of fraud has caused billions in financial losses globally.

Social Engineering Attack Lifecycle

A professional social engineering attack follows structured stages:

1. Reconnaissance

Collecting information from:

- LinkedIn
- Social media
- Company websites

2. Target Selection

Identifying vulnerable individuals.

3. Pretext Creation

Designing a believable scenario.

4. Engagement

Establishing trust and communication.

5. Exploitation

Obtaining credentials or financial transfers.

6. Exit and Cover Tracks

Deleting evidence or escalating access.

Social Engineering vs Technical Hacking

Social Engineering

Targets people

Uses psychology

Hard to detect by
firewalls

Relies on deception

Technical Hacking

Targets systems

Uses code exploits

Can be blocked by patches

Relies on vulnerabilities

Impact of Social Engineering

Social engineering can lead to:

- Identity theft
- Financial fraud
- Data breaches
- Ransomware infections
- Corporate espionage

The damage is often financial and reputational.

Prevention and Defeens

Technical Measures

- Multi-Factor Authentication (MFA)
- Email filtering systems
- DMARC implementation
- Zero Trust Architecture

Real-World Examples

Twitter Internal Breach (2020)

Employees were socially engineered via phone to access internal systems.

Target Data Breach (2013)

Attackers tricked a third-party vendor to gain credentials.

These cases show that even large organizations are vulnerable.

Thank you !!!